

Salesforce MFA 2026 Enforcement Guide

Overview

Salesforce is strengthening its security posture by implementing mandatory technical enforcements for Multi-Factor Authentication (MFA) and introducing stricter requirements for privileged users and sensitive data access. These changes are slated for rollout in mid-2026.

1. Key Enforcement Timelines

Phishing-Resistant MFA (Privileged Users)

Applies to users with the **System Administrator** profile or specific privileged permissions (*Modify All Data, View All Data, Customize Application, or Author Apex*).

- **Sandboxes:** Starting June 22, 2026
- **Production:** Starting July 1, 2026

Mandatory MFA (All Employee Users)

Applies to all employee logins, including direct UI and Single Sign-On (SSO).

- **Sandboxes:** Starting June 22, 2026
- **Production:** Starting July 20, 2026

2. Technical Requirements

Step-up Authentication for Reports & Dashboards

A new framework requires users to complete an MFA challenge when performing sensitive actions (viewing, running, or exporting reports/dashboards).

- **Trigger:** Triggered when the user accesses the report, not just on download.
- **Configurability:** Admins can set the "Step-Up Authentication Period" between **2 and 120 minutes** on the Identity Verification page.

SSO Signal Requirements

For organizations using SSO (Okta, Entra ID, etc.), Salesforce will inspect the SAML or OIDC assertion for specific authentication signals.

Tier	Recognized Signals (ACR/AMR)
Phishing-Resistant	fido , fido2 , pki , X509 , cert , hwk , sc , Smartcard , TLSClient , wia
Standard	multipleauthn , webauthn , otp , passkey , okta_verify , Face , mobiletwofactorcontract
Weak / None	pwd , sms , tel , email

3. Preparation Roadmap & Alternatives

Step 1: Inventory and Audit

- **Identify Privileged Users:** Search for users with the specific "Big 4" permissions or the System Admin profile.
- **Audit SSO Signals:** Use a SAML tracer to inspect the AuthnContextClassRef (SAML) or amr (OIDC) claims.

Step 2: Choose MFA Methods (Alternatives)

- **Alternative A: Hardware Security Keys (Best for Desktop)**
 - Deploy FIDO2/WebAuthn keys (e.g., YubiKey, Google Titan).

- *Pros*: Highest security, phishing-resistant.
- **Alternative B: Built-in Authenticators (Best for Mobility)**
 - Use biometrics like **Touch ID**, **Face ID**, or **Windows Hello**.
 - *Pros*: Seamless user experience, no extra hardware needed.

Note: Standard TOTP apps (Salesforce Authenticator, Google Authenticator) **do not** qualify for privileged users in 2026.

Step 3: Align IdP Configuration

- **Okta:** Configure Authentication Policies to require "Possession factor type is Hardware-protected" for Salesforce Admins. Okta will transmit `hwk` or `swk` signals.
- **Microsoft Entra ID:** Use Conditional Access policies to require phishing-resistant MFA. Map the `Authentication Methods Reference` (AMR) claim to pass signals like `fido` or `x509`.
- **Alternative Backstop:** If you cannot configure your IdP signals correctly, have admins register a **Salesforce-native** security key.

Step 4: Handle Integration/API Users

For legitimate automation/service accounts, you must file a case with **Salesforce Support** to request a permanent technical exemption once enforcement begins.

4. Implementation Checklist

- ☐ **Verify My Domain:** Ensure My Domain is active.
- ☐ **Enable Phishing-Resistant Methods:** Enable built-in authenticators and security keys in Setup.
- ☐ **Pilot in Sandbox:** Test the login flow for one admin.
- ☐ **Communicate:** Alert admins that their login flow will change on July 1, 2026.